

AUDIT

BRONTO UI LOCAL QUALITY PASS

Local quality, dead-code, security-policy, report/PDF, and browser verification pass for the current `@ponchia/ui` working tree.

GENERATED: 2026-06-12 • PROFILE: AUDIT • EVIDENCE STATE: SUPPORTED

1. [Summary](#)
2. [Findings](#)
3. [Evidence ledger](#)
4. [Actions](#)

01 / SUMMARY

The repository is in a strong local state after this pass. The native integrity suite, unit tests, dead-code gate, Checkov policy scan, npm audit, real-browser e2e checks, and Semgrep registry/security scan are green. A local ignored `mise.local.toml` now pins Semgrep for this working tree, so the AI-slop helper's Semgrep leg completes as part of the one-command local review path.

READER OUTCOME

KEEP THE NEW LOCAL GATES AND CONTINUE FROM A GREEN BASE

Basis: verified local commands and generated scanner reports. Next action: keep `check:dead` in the aggregate check chain and keep the repo-local Semgrep activation ignored so local SAST remains reproducible. Recheck: 2026-06-12. Evidence state: supported.

BASIS	Native checks, unit tests, dead-code helper, AI-slop helper, Checkov, Semgrep, and Playwright logs.
NEXT ACTION	Keep the dead-code gate and ignored local Semgrep activation.
RECHECK	2026-06-12

Evidence state: supported · Sources: S1-S9 verified

NATIVE GATES

green

▲ check + test

BROWSER TESTS

579

▲ 579 passed, 9 expected skips

SECURITY POLICY

332

▲ Checkov checks passed

02 / FINDINGS

MAJOR FINDING: DEAD-CODE DETECTION IS NOW A NATIVE GATE

Claim: the project now fails `npm run check` when unused exports or unlisted dead-code/dependency surfaces appear.

Impact: the unused `CSS_IMPORT` export that Knip found can no longer reappear silently outside the normal CI-quality path.

Remediation: `CSS_IMPORT` was made module-local, `knip` was declared as a dev dependency, and `check:dead` was wired into the aggregate check chain.

Dead-code detection is now part of the native check contract.

SCOPE: CURRENT WORKING TREE ON 2026-06-12.

EVIDENCE STATE: SUPPORTED.

Basis: `npm run check:dead`, dead-code helper, and aggregate `npm run check` passed.

SOURCES: [S2](#), [S1](#)

RESOLVED FINDING: CI MANUAL INPUTS NO LONGER TRIP CHECKOV

Claim: the GitHub Actions policy finding `CKV_GHA_7` is resolved.

Impact: the manual CI dispatch still provides an any-branch cross-engine run, but no longer exposes a user parameter that changes the build graph.

Remediation: `workflow_dispatch` is now input-free and manual runs always request cross-engine e2e.

Checkov reports zero failed GitHub Actions checks.

SCOPE: `.GITHUB/WORKFLOWS` IN THE CURRENT WORKING TREE.

EVIDENCE STATE: SUPPORTED.

Basis: `checkov -d . --quiet` reported 332 passed checks and 0 failed checks.

SOURCE: [S3](#)

MAJOR FINDING: BROWSER AND PDF-FACING SURFACES ARE GREEN LOCALLY

Claim: Chromium, Firefox, and WebKit non-pixel e2e coverage passes locally.

Impact: the high-risk surfaces for a CSS-first library are exercised in real engines: a11y, print, responsive overflow, report primitives, PDF export in Chromium, and behavior glue.

Remediation: no product change was required after the browser pass.

Real-browser non-pixel checks pass across the supported local engines.

SCOPE: PLAYWRIGHT E2E NON-PIXEL SPECS ON CHROMIUM, FIREFOX, AND WEBKIT.

EVIDENCE STATE: SUPPORTED.

Basis: Chromium passed 196 tests; Firefox/WebKit passed 383 tests with 9 expected skips.

SOURCES: [S4](#), [S5](#)

RESOLVED FINDING: SEMGREP REGISTRY COVERAGE IS CLEAN THROUGH AN ISOLATED RUNNER

Claim: Semgrep registry/security packs run cleanly when invoked through an isolated `uvx` binary.

Impact: the repository has local SAST coverage through an isolated registry scan as well as the now-repaired repo-local Semgrep activation.

Remediation: two raw ampersands in demo `<title>` elements were escaped after the registry scan reported HTML partial-parse warnings.

Semgrep registry/security scan reports zero findings and zero errors.

SCOPE: REGISTRY/SECURITY PACKS RUN LOCALLY THROUGH `uvx` ON 2026-06-12.

EVIDENCE STATE: SUPPORTED.

Basis: rerun after escaping raw ampersands reported 0 results and 0 errors.

SOURCE: [S8](#)

RESOLVED FINDING: AI-SLOP HELPER COMPLETES AFTER LOCAL SEMGREP ACTIVATION

Claim: the AI-slop helper now completes with native checks, dead-code analysis, and its Semgrep helper leg passing.

Impact: the convenience helper is now a clean one-command anti-slop gate on this machine; local custom Semgrep rules still emit advisory false positives for documented trust labels and intentional CLI output.

Remediation: keep the repo-local `mise.local.toml` activation ignored and tune external custom slop rules separately if their advisory noise becomes blocking.

AI-slop helper completes successfully after local Semgrep activation.

SCOPE: LOCAL AI-SLOP HELPER RUN ON 2026-06-12 AGAINST THIS WORKING TREE.

EVIDENCE STATE: SUPPORTED.

Basis: helper report recorded 12 passed checks, 0 failed checks, and 4 skipped checks; the Semgrep deep leg passed. Separate registry/security packs reported 0 findings and 0 errors.

SOURCES: [S6](#), [S7](#), [S8](#)

RESOLVED FINDING: DARK ACCENT TEXT CLEARS THE APCA ADVISORY BAR

Claim: the core dark accent-as-text pairing now clears the local Lc 45 APCA advisory target.

Impact: the dark palette no longer carries a known perceptual contrast warning under the project's own contrast audit.

Remediation: dark `--accent-strong` was recalibrated and the contrast generator was updated to match the derived token.

Dark accent text now clears the project's Lc 45 APCA advisory target.

SCOPE: CORE DARK PALETTE AND SHIPPED DARK COLORWAYS IN THE CURRENT WORKING TREE.

EVIDENCE STATE: SUPPORTED.

Basis: `npm run check:contrast` completed without APCA advisory shortfalls after rebuilding generated artifacts.

SOURCES: [S9](#), [S1](#)

03 / EVIDENCE LEDGER

Claim, evidence, source, and caveat ledger

CLAIM	EVIDENCE	SOURCE	CAVEAT
Dead-code gate	<code>npm run check:dead</code> , dead-code helper, and aggregate check passed.	S2	Requires <code>knip</code> to stay declared in dev dependencies.
Checkov policy	Checkov reported 332 passed checks and 0 failed checks.	S3	Only GitHub Actions policy was checked by Checkov in this repo.
Browser checks	Chromium passed 196 non-pixel tests; Firefox/WebKit passed 383 with 9 expected skips.	S5	Pixel baselines remain intentionally pinned to Linux/Chromium CI.
Semgrep registry	Isolated Semgrep registry/security scan reported 0 results and 0 errors.	S8	Local custom slop rules still emit known false positives for CLI output and trust-label docs.
AI-slop helper	AI-slop helper reported 12 passed checks, 0 failed checks, and 4 skipped checks.	S6	External custom slop rules still emit known false-positive advisory findings.
Dark accent APCA	<code>npm run check:contrast</code> completed with no APCA warnings.	S9	APCA remains advisory until the project promotes it to a hard gate.

04 / ACTIONS

Keep the dead-code gate in the native check path.

OWNER: MAINTAINER

DUE/RECHECK: 2026-06-12

STATUS: COMPLETE

PRIORITY: MEDIUM

Success criteria: `npm run check:dead` and `npm run check:chain` pass.

SOURCE: C1

Activate local Semgrep command.

OWNER: MAINTAINER

DUE/RECHECK: 2026-06-12

STATUS: COMPLETE

PRIORITY: LOW

Success criteria: the normal `semgrep` command resolves through the repo-local activation and produces JSON/SARIF without a `mise` shim error.

SOURCE: C5

SOURCES

● S1-S9 verified ● 6 claims mapped

NATIVE CHECK AND UNIT-TEST RUN

Verified: local terminal commands in /Users/zeno/bronto/bronto-ui.

2026-06-12

`npm run check` passed with the new `check:dead` gate; `npm test` passed 233 tests; `npm audit --audit-level=moderate` found 0 vulnerabilities.

DEAD-CODE HELPER REPORT

Verified: generated local dead-code helper report.

2026-06-12

Temporary artifact: dead-code helper report for timestamp `20260612-175434`. Result: 1 passed check, 0 failed checks.

CHECKOV AND SECURITY-POLICY SCAN

Verified: local Checkov run after CI workflow cleanup.

2026-06-12

`checkov -d . --quiet` reported 332 passed GitHub Actions checks, 0 failed checks, and 0 skipped checks.

CHROMIUM NON-PIXEL PLAYWRIGHT RUN

Verified: local Playwright Chromium run excluding Linux-only pixel snapshots.

2026-06-12

`npx playwright test --project=chromium` over non-pixel specs passed 196 tests in 49.1 seconds.

FIREFOX AND WEBKIT NON-PIXEL PLAYWRIGHT RUN

Verified: local Playwright cross-engine run.

2026-06-12

`npx playwright test --project=firefox --project=webkit` reported 383 passed tests and 9 expected skips in 1.7 minutes.

AI-SLOP HELPER REPORT

Verified: generated local AI-slop helper report.

2026-06-12

Temporary artifact: AI-slop helper report for timestamp `20260612T160938Z`. Result: 12 passed checks, 0 failed checks, and 4 skipped checks; the Semgrep deep leg passed.

LOCAL SEMGREP ACTIVATION CHECK

Verified: local `semgrep` command resolution and `mise` lookup.

2026-06-12

The normal `semgrep` command now resolves through an ignored repo-local `mise.local.toml` activation; `semgrep --version` and the AI-slop Semgrep helper completed without the prior shim error, and a local custom-rule smoke test emitted JSON/SARIF with 65 advisory findings and 0 errors.

ISOLATED SEMGREP REGISTRY/SECURITY SCAN

Verified: local Semgrep 1.166.0 run through `uvx --from semgrep`.

2026-06-12

Registry/security packs reported 0 results and 0 errors after escaping raw ampersands in `demo/generated.html` and `demo/sources.html`.

CONTRAST GATE AFTER DARK ACCENT CALIBRATION

Verified: local artifact rebuild followed by `npm run check:contrast`.

2026-06-12

The contrast gate completed without the previous dark `--accent-text` APCA advisory shortfalls.